

Manual 23 — Implementación Controlada de DORA

Traducción de proyecto es-419 — no oficial

****Orden de la serie:**** 23

****Base estatutaria principal:**** Reglamento (UE) 2022/2554 (DORA)

****Regla de capas de fuentes:**** el texto estatutario, los actos delegados/de ejecución, los materiales de supervisión, la práctica contractual y los procedimientos internos se mantienen diferenciados.

****Límite:**** Este manual no sustituye el RGPD, NIS2, requisitos prudenciales sectoriales, derecho nacional ni instrucciones de autoridades competentes.

01. Gobernanza y rendición de cuentas

Establezca un marco de resiliencia operativa digital aprobado por el órgano de dirección, con responsabilidades, derechos de decisión, frecuencia de reportes, umbrales de escalamiento y conservación de evidencia. Registre responsables, delegaciones, decisiones materiales, cuestionamientos y seguimiento de remediación.

02. Alcance y aplicabilidad

Determine qué entidades jurídicas, servicios, sucursales, activos TIC y acuerdos de externalización están dentro de DORA. Vincule las conclusiones de alcance a hechos de entidad y servicio; no generalice la aplicabilidad más allá de la evidencia.

03. Marco de gestión de riesgos TIC

Mantenga un marco documentado de gestión de riesgos TIC integrado con gestión de riesgos empresariales. Defina objetivos, dominios de control, apetito/tolerancia, excepciones, pruebas y disparadores de reevaluación.

04. Inventario y dependencias

Mantenga inventarios actuales de activos de información y TIC, sistemas, aplicaciones, flujos de datos, funciones críticas, dependencias, interfaces y servicios de terceros. Relacione servicios de negocio con componentes técnicos y responsables.

05. Protección y prevención

Implemente salvaguardas preventivas proporcionales al riesgo, incluyendo control de acceso, configuración segura, gestión de cambios, protección de red, cifrado, defensas antimalware, vulnerabilidades, desarrollo seguro y controles físicos/ambientales aplicables.

06. Detección

Defina capacidades de monitoreo y detección para actividad anómala, degradación del servicio, fallas de integridad, acceso no autorizado, fallas de control y disrupción de terceros. Conserve lógica de alertas, propiedad, criterios de triage y evidencia.

07. Respuesta

Mantenga procedimientos documentados de respuesta a incidentes TIC que cubran clasificación, mando, comunicación, contención, investigación, coordinación de recuperación, preservación de evidencia, registro de decisiones y rutas de notificación regulatoria.

08. Recuperación y restauración

Defina prioridades de recuperación, objetivos, procedimientos de restauración, procesamiento alterno, secuencia de dependencias, verificaciones de integridad y validación del negocio antes de volver a operación normal.

09. Copias de seguridad y restauración

Use arreglos resilientes de respaldo con alcance, frecuencia, retención, segregación, inmutabilidad o protección equivalente cuando corresponda, pruebas de restauración y evidencia de que los objetivos de recuperación siguen siendo alcanzables.

10. Aprendizaje y mejora

Realice revisiones estructuradas posteriores a incidentes y pruebas. Registre causas raíz, brechas, lecciones, acciones correctivas, responsables, fechas objetivo, evidencia de verificación y disparadores de reevaluación.

11. Comunicación

Mantenga procedimientos de comunicación interna y externa para interrupciones TIC importantes. Defina partes interesadas, aprobación de mensajes, escalamiento, consideraciones de medios/mercado/clientes y responsabilidades de contacto regulatorio.

12. Clasificación de incidentes TIC

Use criterios documentados para clasificar incidentes relacionados con TIC. Mantenga separados los modelos internos de severidad de los criterios regulatorios y revalide umbrales y normas técnicas aplicables antes de publicar y usar.

13. Reporte de incidentes mayores

Mantenga un proceso fail-closed para determinar si un incidente TIC cumple requisitos de reporte de incidente mayor. Registre autoridad competente, campos exigidos, etapas, plazos, evidencia y correcciones. Revalide plantillas y tiempos actuales antes de uso operativo.

14. Notificación voluntaria de amenazas cibernéticas

Mantenga la notificación voluntaria de amenazas cibernéticas significativas separada del reporte obligatorio de incidentes mayores. Documente autoridad de decisión, fundamento, destinatarios y obligaciones resultantes.

15. Estrategia de pruebas

Mantenga un programa de pruebas de resiliencia operativa digital basado en riesgo para sistemas y servicios TIC que soporten funciones críticas o importantes. Defina alcance, frecuencia, independencia, evidencia, remediación y repetición de pruebas.

16. Evaluaciones de vulnerabilidad

Realice evaluaciones de vulnerabilidad con métodos proporcionales a criticidad y exposición. Registre hallazgos, severidad, controles compensatorios, plazos, excepciones, evidencia y verificación de cierre.

17. Pruebas de escenarios y resiliencia

Use pruebas basadas en escenarios para validar resiliencia ante disrupciones severas plausibles. Incluya personas, procesos, tecnología, instalaciones, comunicaciones, dependencias de terceros y decisiones de recuperación.

18. Pruebas de penetración basadas en amenazas

Cuando aplique, gestione TLPT como un régimen de control distinto. Verifique aplicabilidad, alcance, requisitos de testers, expectativas de autoridad, evidencia, remediación y obligaciones de repetición antes de ejecutar.

19. Independencia y competencia de testers

Defina requisitos de independencia, competencia, conflicto de interés, confidencialidad, autorización y evidencia para testers internos y externos. Distinga requisitos regulatorios formales de expectativas internas de calidad.

20. Remediación y repetición de pruebas

Gestione hallazgos mediante un ciclo controlado de remediación con responsable, calificación de riesgo, fecha objetivo, autoridad de excepción, evidencia de cierre y repetición de prueba cuando corresponda.

21. Marco de riesgo de terceros TIC

Mantenga gobernanza para riesgo de terceros TIC en incorporación, debida diligencia, contratación, monitoreo, incidentes, concentración, cambios, renovación, salida y conservación de evidencia.

22. Debida diligencia precontractual

Antes de contratar servicios TIC, evalúe capacidad del proveedor, seguridad, resiliencia, manejo de datos, ajuste legal/regulatorio, subcontratación, dependencias geográficas, auditabilidad, continuidad, viabilidad de salida y concentración.

23. Controles contractuales

Use cláusulas apropiadas a la criticidad del servicio y a DORA. Cubra descripción del servicio, ubicaciones, seguridad, apoyo en incidentes, derechos de acceso/auditoría, continuidad, devolución de datos, terminación, cooperación y acceso regulatorio cuando aplique.

24. Subcontratación y riesgo de cadena

Identifique cadenas materiales de subcontratación, dependencias críticas, ubicaciones, riesgo de sustitución, concentración, notificación de cambios y obligaciones aguas abajo. No trate la supervisión del proveedor principal como eliminación del riesgo de cadena.

25. Riesgo de concentración

Evalúe concentración entre proveedores, servicios, tecnologías, regiones, ubicaciones de datos, infraestructura común y sustituibilidad. Documente supuestos, escenarios de estrés, mitigaciones y decisiones de gestión.

26. Registro de información

Mantenga el registro de información requerido para acuerdos TIC relevantes usando estructura y campos vigentes. Revalide plantillas, taxonomía, expectativas de presentación e instrucciones de autoridad antes de presentar.

27. Proveedores TIC críticos

Mantenga controles para dependencias de proveedores designados o potencialmente sujetos al marco europeo de supervisión de proveedores TIC críticos. Distinga esa supervisión de las responsabilidades continuas de la entidad financiera.

28. Planificación de salida y transición

Cree planes probados de salida y transición para servicios TIC que soportan funciones críticas o importantes. Incluya portabilidad de datos, proveedores alternos, posibilidad de insourcing, secuencia, continuidad, transferencia de conocimiento, disparadores contractuales y riesgo residual.

29. Métricas de resiliencia operativa

Defina métricas para incidentes, recuperación, pruebas, desempeño de terceros, vulnerabilidades, remediación, excepciones, concentración y efectividad de controles. Vincule métricas con decisiones y escalamiento.

30. Evidencia y preparación supervisora

Mantenga objetos de evidencia para cada control material: política, responsable, procedimiento, registro operativo, resultado de prueba, excepción, remediación, aprobación cuando corresponda y reevaluación. Asegure soporte para auditoría interna, aseguramiento externo y solicitudes de autoridades.

31. Localización y control de implementación

Traduzca únicamente desde una fuente inglesa exacta congelada. Preserve términos legales/regulatorios, distinciones de reporte, terminología de terceros, límites de alcance y condición de traducción no oficial. Ejecute controles de paridad estructural y semántica antes de generar candidatos.

32. Vigilancia de fuentes, cambios, procedencia y publicación

Antes de congelar y publicar, revalide aplicabilidad del Reglamento (UE) 2022/2554, actos delegados/de ejecución, materiales ESA, normas técnicas de reporte de incidentes, TLPT, especificaciones del registro de información y actualizaciones supervisoras. Vincule commit fuente, localizaciones, binarios DOCX/PDF, SHA-256, QA de renderizado/accesibilidad, seguridad de workflows, estado del predecesor y reconciliación del registro. Si no quedan

defectos materiales y todas las puertas objetivas están verdes, publique bajo la autorización permanente del repositorio.

Registro mínimo de control para cada capítulo

Para cada capítulo sustantivo, los registros de implementación deben identificar: capa de fuente aplicable; decisión de aplicabilidad; responsable; procedimiento operativo; objeto/ubicación de evidencia; método de revisión o prueba; ruta de excepción/remediación; y disparador de reevaluación.